

Shadow IT SaaS Usage & Data Exposure response

Identity / SaaS · **High** severity · SOC IR Playbook

Incident type	Policy Violation - Unauthorised SaaS Usage
Severity	High
Priority	High
Detection sources	CASB, DLP, Proxy Logs, SIEM, Endpoint Agents, Shadow IT Discovery Tools, Employee Reports

Scenario

An employee or team uses an unapproved SaaS application (e.g., personal Google Drive, Dropbox, Notion, ChatGPT) for work-related purposes, transferring corporate data without security oversight. This can result in unauthorised data exposure, regulatory breaches or insider misuse.

MITRE ATT&CK

T1087.003, T1213, T1537

Preparation

Implement CASB platform Discover and monitor all SaaS usage beyond sanctioned apps Set SaaS usage policies Clearly define approved vs. unapproved services Apply DLP on endpoints and cloud Detect sensitive file uploads or clipboard transfers Integrate proxy/firewall logs Track SaaS usage by domain/IP and user Train users on data handling and shadow IT risks Promote awareness of compliance and approved tools

Detection & Analysis

Alert triggered CASB or proxy detects unsanctioned SaaS usage or DLP flags sensitive file transfer Identify the user and device Match to IP, user ID and machine used for the transfer Analyse the data shared Determine if documents contained PII, PHI, customer info or internal IP Investigate SaaS app risk profile Evaluate whether the app has poor security practices or terms of service violations

Containment

Block access to the SaaS app Use CASB, firewall or proxy rules to prevent further use Suspend user's internet or cloud access Temporarily if data exposure is severe or continued use is suspected Notify user and manager Conduct initial investigation interview if necessary Prevent download/export of shared data Remove permissions or delete from the third-party app if possible

Eradication

Remove company data from unapproved platforms Where feasible, contact the vendor or request user deletion Revoke SaaS OAuth permissions From user or enterprise accounts integrated with unapproved services Tighten app controls Configure CASB to auto-block newly discovered unapproved apps in high-risk categories Remove access to shared data from external parties If data was shared via link or collaboration features

Recovery

Reinstate user access under monitoring After risk is remediated and policy is acknowledged Monitor future SaaS usage Apply stricter controls and alerts on repeat violations Validate that no further data copies exist Search endpoints and cloud storage for duplicates Implement formal app request workflows Make it easier for users to request approval of new tools securely

Lessons Learned & Reporting

Perform user and data risk review Understand business reasons for Shadow IT use and sensitivity of data involved Update SaaS control policies Include newly discovered apps in the unapproved/blocked list or formally review them Educate users Add targeted training or post-incident briefings Report to compliance/management If regulatory data

was exposed or customer confidentiality was breached Review and update DLP/CASB configurations Based on gaps that allowed this usage to go undetected

Tools typically involved

CASB (e.g., Microsoft Defender for Cloud Apps, Netskope, Skyhigh Security); DLP (e.g., Forcepoint, Microsoft Purview, Symantec DLP); SIEM (e.g., Splunk, Sentinel); Web Proxies and NGFW (e.g., Zscaler, Palo Alto, Fortinet); Endpoint Monitoring Tools (e.g., CrowdStrike, Tanium); SaaS Access Governance Tools (e.g., BetterCloud, DoControl)

Success metrics (SLA targets)

Detection Time <5 minutes from data upload or SaaS access SaaS Access Block Time <15 minutes from alert
Data Removal Completion Within 24 hours for public or third-party exposure User Education Completion 100% of involved users re-briefed within 3 business days Policy Review Update Within 7 days to incorporate lessons learned